

BurnVault

Current Risk Summary report

Friday March 06 2026 12:52:39 GMT+0000 (Coordinated Universal Time)

Project description: No description

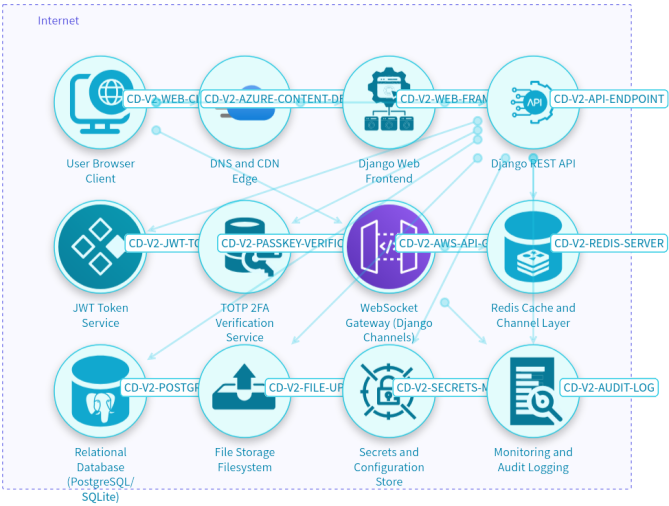
Filtered by: Critical risk High risk Medium risk Low risk Very Low risk Unmitigated threats No mitigation planned

This report only includes threats that match the filters above.

Unique ID: BurnVault

Owner: Mujeeb U Rehman

Workflow state: Draft



Content menu

[Current risk summary](#)

[Components](#)

[Accepted Risks](#)

[Current Risks](#)

- [Django REST API](#)
- [Django Web Frontend](#)
- [DNS and CDN Edge](#)
- [File Storage Filesystem](#)
- [JWT Token Service](#)
- [Monitoring and Audit Logging](#)
- [Redis Cache and Channel Layer](#)
- [Relational Database \(PostgreSQL/SQLite\)](#)
- [Secrets and Configuration Store](#)
- [TOTP 2FA Verification Service](#)
- [User Browser Client](#)
- [WebSocket Gateway \(Django Channels\)](#)

Current Risk summary

- Inherent risk description:** The Inherent Risk before countermeasures were applied.
- **Risk Rating:** 66.94366455078125%  High
- The Current Risk description (the risk we are at now):** The Current Risk is based on the current implementation status of the countermeasures and test results.
- **Risk Rating:** 66.94366455078125%  High
- Projected Risk description:** The Projected Risk is the level of risk that would be reached should the required countermeasures be implemented.
- **Risk Rating:** 66.94366455078125%  High

Components

- Django REST API
- Django Web Frontend
- DNS and CDN Edge
- File Storage Filesystem
- JWT Token Service
- Monitoring and Audit Logging
- Redis Cache and Channel Layer
- Relational Database (PostgreSQL/SQLite)
- Secrets and Configuration Store
- TOTP 2FA Verification Service
- User Browser Client
- WebSocket Gateway (Django Channels)

Accepted Risks

No data

Current Risks

Component: Django REST API

 Use case: Information Disclosure CRT1. Threat name: Attackers abuse of missing or insecure security headers - Inherent risk: High - Current risk: High - Projected risk: High - State: Exposed - CR1. Countermeasure name: Implement strict security headers - Status: RECOMMENDED CRT2. Threat name: Attackers exploit misconfiguration - Inherent risk: Critical - Current risk: Critical - Projected risk: Critical - State: Exposed - CR2. Countermeasure name: Implement regular security audits and configuration reviews - Status: RECOMMENDED CRT3. Threat name: Attackers take advantage of sensitive data exposure - Inherent risk: High - Current risk: High - Projected risk: High - State: Exposed - CR3. Countermeasure name: Deploy transparent data encryption on storage and end to end encryption over networks - Status: RECOMMENDED
 Use case: Denial of Service CRT4. Threat name: Attackers carry out denial of service by API abuse/flooding - Inherent risk: High - Current risk: High - Projected risk: High - State: Exposed - CR4. Countermeasure name: Implement rate limiting and robust load balancing - Status: RECOMMENDED
 Use case: Elevation of Privilege CRT5. Threat name: Attackers gain elevated privilege from broken function level authorization - Inherent risk: High - Current risk: High - Projected risk: High - State: Exposed - CR5. Countermeasure name: Implement role-based access control (RBAC) - Status: RECOMMENDED
 Use case: Tampering CRT6. Threat name: Attackers perform injection attacks and scripting - Inherent risk: High - Current risk: High - Projected risk: High - State: Exposed - CR6. Countermeasure name: Implement proper authorization checks - Status: RECOMMENDED
 Use case: Repudiation CRT7. Threat name: Lack of evidences of actions due to insufficient auditing and logging - Inherent risk: Medium - Current risk: Medium - Projected risk: Medium - State: Exposed - CR7. Countermeasure name: Enforce logging and monitoring - Status: RECOMMENDED

Component: Django Web Frontend

 **Use case:** Tampering

CRT8. Threat name: Attackers craft and upload malicious files or inject malicious inputs, e.g., code/command execution

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR8. Countermeasure name:** Validate all user inputs including using built-in mechanisms
- Status:** RECOMMENDED

CRT9. Threat name: Attackers gain access to the application data, e.g., secrets

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR9. Countermeasure name:** Safeguard sensitive information
- Status:** RECOMMENDED

CRT10. Threat name: Attackers gain unauthorized access by manipulating input parameters, e.g., IDOR or mass assignment

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR10. Countermeasure name:** Implement proper object references and binding
- Status:** RECOMMENDED

 **Use case:** Elevation of Privilege

CRT11. Threat name: Attackers craft input data to execute arbitrary SQL queries

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR11. Countermeasure name:** Implement SQLi protections, e.g., parameterized queries
- Status:** RECOMMENDED

CRT12. Threat name: Attackers gain access to the application or privileges in the environment

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR12. Countermeasure name:** Implement proper access controls and authorization checks
- Status:** RECOMMENDED

CRT13. Threat name: Attackers gain access to the system using a vulnerable framework or dependency

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR13. Countermeasure name:** Use up-to-date framework and well-tested routines and dependencies
- Status:** RECOMMENDED

CRT14. Threat name: Attackers take control of a user's session

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR14. Countermeasure name:** Implement secure session management including using built-in mechanisms
- Status:** RECOMMENDED

 **Use case:** Spoofing

CRT15. Threat name: Attackers craft links to execute malicious actions (CSRF)

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR15. Countermeasure name:** Use anti-CSRF tokens and built-in mechanisms
- Status:** RECOMMENDED

 **Use case:** Information Disclosure

CRT16. Threat name: Attackers gain data or access exploiting insecure configuration or defaults

- **Inherent risk:** ⬆ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆ High
- **State:** Exposed
- **CR16. Countermeasure name:** Review defaults and configuration files
- **Status:** RECOMMENDED

Component: DNS and CDN Edge

 **Use case:** Tampering

CRT17. Threat name: Unauthorized access and data breaches due to misconfigured cloud resources

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR17. Countermeasure name:** Use only approved services
- **Status:** RECOMMENDED

 **Use case:** Spoofing

CRT18. Threat name: Unauthorized access to TLS certificates in Azure Key vault leading to impersonation

- **Inherent risk:** ⬆ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆ High
- **State:** Exposed
- **CR18. Countermeasure name:** Use a secure certificate management process
- **Status:** RECOMMENDED

 **Use case:** Elevation of Privilege

CRT19. Threat name: Unauthorized access via misconfigured Azure RBAC role assignments

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR19. Countermeasure name:** Follow just enough administration (least privilege) principle
- **Status:** RECOMMENDED

 **Use case:** Repudiation

CRT20. Threat name: Undetected unauthorized activities due to lack of resource logs

- **Inherent risk:** ⬆ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆ High
- **State:** Exposed
- **CR20. Countermeasure name:** Enable network logging for security investigation
- **Status:** RECOMMENDED

Component: File Storage Filesystem

 **Use case:** Tampering

CRT21. Threat name: Advanced malware and zero-day payloads

- **Inherent risk:** ⬆ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆ High
- **State:** Exposed
- **CR21. Countermeasure name:** Deploy multi-engine malware scanning and CDR
- **Status:** RECOMMENDED
- **CR22. Countermeasure name:** Perform deep content inspection of magic bytes
- **Status:** RECOMMENDED

CRT22. Threat name: Client-side attacks via malicious metadata

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** 🔴 Critical
- **State:** Exposed
- **CR23. Countermeasure name:** Strip EXIF and sensitive metadata during processing
- **Status:** RECOMMENDED
- **CR24. Countermeasure name:** Configure a strict Content Security Policy (CSP)

- **Status:** RECOMMENDED

CRT23. Threat name: Path traversal and file overwriting

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed
- **CR25. Countermeasure name:** Generate randomized UUID filenames for storage
 - **Status:** RECOMMENDED
- **CR26. Countermeasure name:** Sanitize and normalize filename inputs
 - **Status:** RECOMMENDED

 **Use case:** Elevation of Privilege

CRT24. Threat name: Remote code execution via web shell

- **Inherent risk:**  Medium
- **Current risk:**  Medium
- **Projected risk:**  Medium
- **State:** Exposed
- **CR27. Countermeasure name:** Store uploads in a non-executable isolated directory
 - **Status:** RECOMMENDED
- **CR28. Countermeasure name:** Implement server-side allow-list for file extensions
 - **Status:** RECOMMENDED

 **Use case:** Denial of Service

CRT25. Threat name: Resource exhaustion and Denial of Service

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed
- **CR29. Countermeasure name:** Enforce maximum file size and upload frequency limits
 - **Status:** RECOMMENDED
- **CR30. Countermeasure name:** Offload uploads to cloud buckets with lifecycle policies
 - **Status:** RECOMMENDED

 **Use case:** Information Disclosure

CRT26. Threat name: Unauthorized access to private assets

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed
- **CR31. Countermeasure name:** Mandate authentication and MFA for all uploads
 - **Status:** RECOMMENDED
- **CR32. Countermeasure name:** Use pre-signed URLs with short TTLs for retrieval
 - **Status:** RECOMMENDED

Component: JWT Token Service

 **Use case:** Tampering

CRT27. Threat name: Algorithm tampering

- **Inherent risk:**  Critical
- **Current risk:**  Critical
- **Projected risk:**  Critical
- **State:** Exposed
- **CR33. Countermeasure name:** Enforce secure JWT algorithm validation
 - **Status:** RECOMMENDED

CRT28. Threat name: Insecure JWT secret Key

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed
- **CR34. Countermeasure name:** Use strong, high-entropy secret keys
 - **Status:** RECOMMENDED

CRT29. Threat name: JWT kid injection for Key confusion

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed

- **CR35. Countermeasure name:** Sanitize and validate kid parameter
- **Status:** RECOMMENDED

- CRT30. Threat name:** Unvalidated jku/xSu header leading to SSRF
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR36. Countermeasure name:** Whitelist trusted domains for jku/xSu headers
 - **Status:** RECOMMENDED

 **Use case:** Spoofing

- CRT31. Threat name:** Inadequate token revocation
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR37. Countermeasure name:** Maintain and check a revocation list to invalidate tokens early
 - **Status:** RECOMMENDED

- CRT32. Threat name:** Insufficient signature verification
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR38. Countermeasure name:** Enforce valid cryptographic signature verification for JWTs
 - **Status:** RECOMMENDED

- CRT33. Threat name:** Man-in-the-middle attack
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR39. Countermeasure name:** Use HTTPS to encrypt JWT tokens in transit
 - **Status:** RECOMMENDED

- CRT34. Threat name:** Token theft
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR40. Countermeasure name:** Use short-lived JWT tokens to minimize misuse risks
 - **Status:** RECOMMENDED
 - **CR41. Countermeasure name:** Implement refresh tokens for seamless token renewal
 - **Status:** RECOMMENDED

Component: Monitoring and Audit Logging

 **Use case:** Repudiation

- CRT35. Threat name:** Attackers rely on the lack of monitoring and timely response to achieve their goals without being detected
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR42. Countermeasure name:** Ensure high-value transactions have an audit trail with integrity controls to prevent tampering or deletion
 - **Status:** RECOMMENDED
 - **CR43. Countermeasure name:** Log and reject all data validation failures
 - **Status:** RECOMMENDED
 - **CR44. Countermeasure name:** Ensure that logs are generated in a format that log management solutions can easily consume
 - **Status:** RECOMMENDED

 **Use case:** Tampering

- CRT36. Threat name:** The attacker injects, manipulates or forges malicious log entries in the log file, allowing them to mislead a log audit, cover traces of attack, or perform log injection attacks
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR45. Countermeasure name:** Develop a log retention policy
 - **Status:** RECOMMENDED
 - **CR46. Countermeasure name:** Log details of user actions within the system

- **Status:** RECOMMENDED

Component: Redis Cache and Channel Layer

🔒 **Use case:** Denial of Service

- CRT37. Threat name:** Attackers cause denial of service through command flooding
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR47. Countermeasure name:** Implement rate limiting and resource throttling
 - **Status:** RECOMMENDED

🔒 **Use case:** Information Disclosure

- CRT38. Threat name:** Attackers exploit default configurations and misconfigurations
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR48. Countermeasure name:** Harden Redis configuration and disable dangerous commands
 - **Status:** RECOMMENDED

- CRT39. Threat name:** Attackers intercept data due to unencrypted communications
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR49. Countermeasure name:** Enforce TLS encryption for all connections
 - **Status:** RECOMMENDED

🔒 **Use case:** Elevation of Privilege

- CRT40. Threat name:** Attackers exploit outdated Redis vulnerabilities
- **Inherent risk:**  Medium
 - **Current risk:**  Medium
 - **Projected risk:**  Medium
 - **State:** Exposed
 - **CR50. Countermeasure name:** Regularly update Redis to the latest secure version
 - **Status:** RECOMMENDED

🔒 **Use case:** Spoofing

- CRT41. Threat name:** Attackers gain unauthorized access due to weak authentication
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR51. Countermeasure name:** Implement strong authentication and ACLs
 - **Status:** RECOMMENDED

🔒 **Use case:** Tampering

- CRT42. Threat name:** Attackers tamper with data due to lack of data integrity controls
- **Inherent risk:**  Medium
 - **Current risk:**  Medium
 - **Projected risk:**  Medium
 - **State:** Exposed
 - **CR52. Countermeasure name:** Implement data integrity verification and access logging
 - **Status:** RECOMMENDED

Component: Relational Database (PostgreSQL/SQLite)

🔒 **Use case:** Denial of Service

- CRT43. Threat name:** Attackers cause denial of service through resource exhaustion
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed

- **CR53. Countermeasure name:** Implement rate limiting and resource throttling
- **Status:** RECOMMENDED

🔗 **Use case:** Information Disclosure

- CRT44. Threat name:** Attackers exfiltrate data due to insecure backup procedures
- **Inherent risk:** 🟡 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🟡 Critical
 - **State:** Exposed
 - **CR54. Countermeasure name:** Implement secure backup procedures with encryption and access controls
 - **Status:** RECOMMENDED

- CRT45. Threat name:** Attackers exploit misconfigurations in postgresql settings
- **Inherent risk:** 🟡 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🟡 Critical
 - **State:** Exposed
 - **CR55. Countermeasure name:** Harden postgresql configuration and restrict network access
 - **Status:** RECOMMENDED

- CRT46. Threat name:** Attackers exploit sql injection vulnerabilities
- **Inherent risk:** 🟡 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🟡 High
 - **State:** Exposed
 - **CR56. Countermeasure name:** Use parameterized queries and validate inputs
 - **Status:** RECOMMENDED

- CRT47. Threat name:** Attackers intercept data due to unencrypted communications
- **Inherent risk:** 🟡 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🟡 High
 - **State:** Exposed
 - **CR57. Countermeasure name:** Enforce TLS encryption for all connections
 - **Status:** RECOMMENDED
 - **CR58. Countermeasure name:** Encrypt data at rest using Transparent Data Encryption (TDE) or Volume-Level Encryption
 - **Status:** RECOMMENDED

🔗 **Use case:** Tampering

- CRT48. Threat name:** Attackers exploit outdated postgresql vulnerabilities
- **Inherent risk:** 🟡 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🟡 Critical
 - **State:** Exposed
 - **CR59. Countermeasure name:** Apply regular security patches and minor version updates
 - **Status:** RECOMMENDED
 - **CR60. Countermeasure name:** Regularly update postgresql to the latest secure version
 - **Status:** RECOMMENDED

- CRT49. Threat name:** Attackers tamper with data due to insecure file permissions
- **Inherent risk:** 🟡 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🟡 High
 - **State:** Exposed
 - **CR61. Countermeasure name:** Enforce secure file permissions on PostgreSQL database files
 - **Status:** RECOMMENDED

🔗 **Use case:** Spoofing

- CRT50. Threat name:** Attackers gain unauthorized access due to weak authentication
- **Inherent risk:** 🟡 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🟡 High
 - **State:** Exposed
 - **CR62. Countermeasure name:** Implement multi-factor authentication (MFA) using identity providers
 - **Status:** RECOMMENDED
 - **CR63. Countermeasure name:** Implement robust authentication and role-based access control
 - **Status:** RECOMMENDED

🔗 **Use case:** Elevation of Privilege

- CRT51. **Threat name:** Attackers misuse insider privileges
- Inherent risk: 🟡 Medium
 - Current risk: 🟡 Medium
 - Projected risk: 🟡 Medium
 - State: Exposed
 - CR64. **Countermeasure name:** Enable comprehensive auditing and logging of database activity
 - Status: RECOMMENDED

Component: Secrets and Configuration Store

- 🔗 **Use case:** Information Disclosure
- CRT52. **Threat name:** An attacker exploits weak access controls to retrieve sensitive secrets
- Inherent risk: 🔴 Critical
 - Current risk: 🔴 Critical
 - Projected risk: 🔴 Critical
 - State: Exposed
 - CR65. **Countermeasure name:** Implement strict access control policies
 - Status: RECOMMENDED
- CRT53. **Threat name:** Compromised systems reuse leaked or old secrets
- Inherent risk: 🔴 High
 - Current risk: 🔴 High
 - Projected risk: 🔴 High
 - State: Exposed
 - CR66. **Countermeasure name:** Implement automatic secret rotation
 - Status: RECOMMENDED
- CRT54. **Threat name:** Overly permissive secrets sharing between services leads to data leakage
- Inherent risk: 🔴 Critical
 - Current risk: 🔴 Critical
 - Projected risk: 🔴 Critical
 - State: Exposed
 - CR67. **Countermeasure name:** Restrict secret sharing based on least privilege
 - Status: RECOMMENDED
- CRT55. **Threat name:** Secrets are stored without encryption, leading to potential exposure
- Inherent risk: 🔴 Critical
 - Current risk: 🔴 Critical
 - Projected risk: 🔴 Critical
 - State: Exposed
 - CR68. **Countermeasure name:** Enforce encryption of secrets at rest and in transit
 - Status: RECOMMENDED

- 🔗 **Use case:** Elevation of Privilege
- CRT56. **Threat name:** Attackers exploit vulnerabilities in the Secrets Manager API
- Inherent risk: 🔴 Critical
 - Current risk: 🔴 Critical
 - Projected risk: 🔴 Critical
 - State: Exposed
 - CR69. **Countermeasure name:** Secure the API with strong authentication and input validation
 - Status: RECOMMENDED

Component: TOTP 2FA Verification Service

- 🔗 **Use case:** Denial of Service
- CRT57. **Threat name:** Denial of Service (DoS/DDoS) attack on auth endpoints
- Inherent risk: 🔴 High
 - Current risk: 🔴 High
 - Projected risk: 🔴 High
 - State: Exposed
 - CR70. **Countermeasure name:** Use a web application firewall (WAF) and DDoS protection services
 - Status: RECOMMENDED
 - CR71. **Countermeasure name:** Implement strict rate limiting
 - Status: RECOMMENDED

- 🔗 **Use case:** Information Disclosure
- CRT58. **Threat name:** Domain or DNS hijacking redirects users to a malicious site
- Inherent risk: 🔴 Critical
 - Current risk: 🔴 Critical
 -

- **Projected risk:** ⚠ Critical
- **State:** Exposed
- **CR72. Countermeasure name:** Secure domain registrar account with MFA and transfer locks
 - **Status:** RECOMMENDED
- **CR73. Countermeasure name:** Implement DNSSEC to ensure DNS integrity
 - **Status:** RECOMMENDED

- CRT59. Threat name:** Server database breach exposes public keys and user data
- **Inherent risk:** ⚠ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⚠ High
 - **State:** Exposed
 - **CR74. Countermeasure name:** Apply the principle of least privilege for database access
 - **Status:** RECOMMENDED
 - **CR75. Countermeasure name:** Implement robust logging and monitoring for suspicious activity
 - **Status:** RECOMMENDED
 - **CR76. Countermeasure name:** Encrypt sensitive data at rest
 - **Status:** RECOMMENDED

- CRT60. Threat name:** User account enumeration via login error messages
- **Inherent risk:** ⚠ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⚠ High
 - **State:** Exposed
 - **CR77. Countermeasure name:** Return generic error messages for both invalid users and invalid credentials
 - **Status:** RECOMMENDED

🔗 **Use case:** Spoofing

- CRT61. Threat name:** Replay attack using a captured authentication assertion
- **Inherent risk:** ⚠ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⚠ High
 - **State:** Exposed
 - **CR78. Countermeasure name:** Validate that challenges have not been seen before
 - **Status:** RECOMMENDED
 - **CR79. Countermeasure name:** Generate a unique, single-use challenge for each login attempt
 - **Status:** RECOMMENDED

Component: User Browser Client

🔗 **Use case:** Spoofing

- CRT62. Threat name:** Clickjacking
- **Inherent risk:** ⚠ Critical
 - **Current risk:** 🔴 Critical
 - **Projected risk:** ⚠ Critical
 - **State:** Exposed
 - **CR80. Countermeasure name:** Detect and block UI redressing attempts
 - **Status:** RECOMMENDED

🔗 **Use case:** Tampering

- CRT63. Threat name:** Client-side insecure data storage
- **Inherent risk:** ⚠ Critical
 - **Current risk:** 🔴 Critical
 - **Projected risk:** ⚠ Critical
 - **State:** Exposed
 - **CR81. Countermeasure name:** Prevent storage of sensitive data on the client
 - **Status:** RECOMMENDED
- CRT64. Threat name:** Cross-site scripting
- **Inherent risk:** ⚠ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⚠ High
 - **State:** Exposed
 - **CR82. Countermeasure name:** Avoid unsafe DOM manipulation and isolate untrusted scripts
 - **Status:** RECOMMENDED
- CRT65. Threat name:** Man-in-the-middle attacks
- **Inherent risk:** ⚠ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⚠ High
 - **State:** Exposed

- **CR83. Countermeasure name:** Ensure secure communication and validate external resources
- **Status:** RECOMMENDED

Component: WebSocket Gateway (Django Channels)

🔒 **Use case:** Tampering

CRT66. Threat name: Configuration drift

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR84. Countermeasure name:** Enable AWS Config
- **Status:** RECOMMENDED

🔒 **Use case:** Lateral Movement

CRT67. Threat name: Delayed threat detection

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR85. Countermeasure name:** Implement Amazon CloudWatch alarms
- **Status:** RECOMMENDED

🔒 **Use case:** Repudiation

CRT68. Threat name: Lack of audit trails

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR86. Countermeasure name:** Enable AWS CloudTrail
- **Status:** RECOMMENDED

CRT69. Threat name: Unmonitored changes and activities

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR87. Countermeasure name:** Implement logging
- **Status:** RECOMMENDED

🔒 **Use case:** Information Disclosure

CRT70. Threat name: Non-compliance with security best practices

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR88. Countermeasure name:** Use AWS Security Hub
- **Status:** RECOMMENDED

🔒 **Use case:** Elevation of Privilege

CRT71. Threat name: Unauthorized access

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR89. Countermeasure name:** Implement least privilege access
- **Status:** RECOMMENDED

End of Current Risk Report

